

피싱 · 스미싱 대응 가이드 (참고용 편집본)

본 문서는 일반적으로 알려진 피싱 대응 원칙을 프로젝트 학습용으로 정리한 참고 자료입니다.
· 특정 기관의 공식 발간물이 아닙니다.

1. 피싱이란

피싱(Phishing)은 신뢰할 수 있는 대상(은행, 공공기관, 지인 등)을 사칭하여 피해자로부터 계정 정보, 금융정보, 개인정보를 탈취하거나 악성코드를 설치시키는 사회공학적(Social Engineering) 공격 기법이다. 이메일, 문자메시지, 전화, 웹사이트 등 다양한 채널을 통해 이루어진다.

2. 피싱의 주요 유형

- 이메일 피싱(Email Phishing): 불특정 다수에게 대량으로 발송되는 사칭 이메일
- 스피어 피싱(Spear Phishing): 특정 개인 · 조직을 표적으로 맞춤 제작된 피싱
- 스미싱(Smishing): 문자메시지(SMS)를 통해 악성 링크를 유포하는 공격
- 보이스 피싱(Voice Phishing): 전화 통화로 금융기관 · 수사기관을 사칭하는 공격
- 파밍(Pharming): DNS 조작 등으로 정상 사이트 접속 시 가짜 사이트로 유도하는 공격

3. 피싱 이메일 식별 체크리스트

- 발신자 이메일 주소가 정상 도메인과 미세하게 다름 (예: 문자 하나 치환)
- '계정이 곧 잠깁니다', '24시간 내 확인 필요' 등 긴급성 · 공포감을 유발하는 문구
- 문법 오류, 어색한 번역투 문장, 부자연스러운 존칭
- 로그인 정보, 카드번호, 인증번호 등 민감정보 입력을 요구
- .exe, .scr, .js, 매크로 포함 문서 등 실행 가능한 첨부파일
- 마우스를 올렸을 때 표시되는 실제 링크 주소와 표기된 텍스트가 불일치

4. 악성 URL 식별 체크리스트 (구조적 특징)

- IP 주소를 도메인 대신 직접 사용하는 URL
- URL에 '@' 기호가 포함되어 실제 목적지를 숨기는 경우
- 정상 도메인과 유사하지만 하이픈 · 숫자가 추가된 유사 도메인 (타이포스퀘팅)
- HTTPS를 사용하지 않거나, 반대로 도메인 문자열 안에 'https'라는 단어를 끼워 넣어 안전한 사이트처럼 보이게 하는 트릭
- bit.ly 등 단축 URL 서비스를 과도하게 사용
- 생성된 지 얼마 되지 않은 신규 등록 도메인
- 유효하지 않거나 자체 서명된 SSL 인증서
- 최종 목적지에 도달하기까지 과도한 리다이렉트 발생
- 페이지 내 링크(anchor)의 상당수가 실제 표시 도메인과 다른 외부 도메인을 가리킴

5. 사고 대응 절차

5-1. 의심스러운 이메일 · 문자를 받았을 때

링크를 클릭하거나 첨부파일을 열지 말고, 발신자에게 별도 채널(전화 등)로 진위를 확인한다. 확인이 어려우면 즉시 삭제하고 스팸으로 신고한다.

5-2. 실수로 의심 링크를 클릭했을 때

네트워크 연결을 차단하고, 백신으로 전체 검사를 수행한다. 로그인 정보를 입력하지 않았다면 추가 정보 입력을 중단한다.

5-3. 개인정보 · 금융정보를 이미 입력했을 때

즉시 해당 계정 비밀번호를 변경하고, 금융기관에 연락해 카드·계좌 이용을 정지한다. 동일 비밀번호를 사용하는 다른 서비스의 비밀번호도 함께 변경한다.

6. 신고 및 문의 채널

- 한국인터넷진흥원(KISA) 인터넷침해대응센터: 국번없이 118
- 경찰청 사이버수사국: 국번없이 182
- 금융감독원 불법금융신고센터: 1332

7. 조직 차원의 예방 수칙

- 임직원 대상 정기적인 보안 인식 교육 실시
- 이메일 필터링 및 스팸 차단 솔루션 도입
- 로그인 시 다중 인증(MFA) 적용
- 정기적인 피싱 모의훈련을 통한 대응 역량 점검
- 의심 사례 발견 시 즉시 보고할 수 있는 내부 신고 체계 마련